TP : MISE EN ŒUVRE DU FRAMEWORK NIST CSF DANS UNE PME

COURS : LES NORMES DE SECURITE

ENCADREUR : MR DOUCKAGA

CADRE DE REFERENCE : NIST CSF

ECOLE : BEM TECH

ENONCE DU PROJET :

TP : Mise en œuvre du Framework NIST CSF dans une PME

Objectifs du TP

À la fin de ce TP, tu seras capable de :

- Comprendre la structure du **NIST Cybersecurity Framework**
- Identifier les risques de sécurité dans une entreprise
- Appliquer les 5 fonctions du CSF :
  - Identify
  - Protect
  - Detect
  - Respond
  - Recover
- Proposer des mesures de sécurité adaptées

Contexte (Cas pratique)

Tu es consultant en cybersécurité dans une PME appelée **DAGOSTA IT** située à Dakar.

Situation:

- 25 employés
- Réseau local + accès Internet
- Serveur contenant :
  - données clients
  - factures
- Aucun système de sécurité formel
- Antivirus basique installé
- Pas de sauvegarde régulière

L'entreprise veut sécuriser son système d'information.

CS Scanné avec CamScanner

Partie 1 : IDENTIFY (Identifier)

Travail demandé

1. Identifier les actifs critiques :
   - Matériel
   - Logiciel
   - Données
2. Identifier les risques possibles

Partie 2 : PROTECT (Protéger)

Travail demandé

Proposer des mesures de protection.

Partie 3 : DETECT (Détecter)

Travail demandé

Comment détecter les incidents ?

Partie 4 : RESPOND (Répondre)

Travail demandé

Que faire en cas d'attaque ?

Partie 5 : RECOVER (Récupérer)

Travail demandé

Comment assurer la reprise ?

Scanné avec CamScanner

Résultats **attendus**

Tu dois fournir :

- Un rapport PDF contenant :
  - Analyse des risques
  - Mesures proposées
  - Tableau d'évaluation
  - schéma réseau sécurisé

Cas pratique

- Implémenter un mini SIEM avec :
  - Wazuh
  - ELK Stack
- Simuler une attaque (phishing ou malware)
- Analyser les logs

Conclusion

Ce TP te permet de passer de la **théorie du NIST** à une **application réelle en entreprise**, ce qui est essentiel pour :

- les projets de mémoire
- les stages
- les certifications en cybersécurité

CS Scanné avec CamScanner

INTRODUCTION

L'OBJECTIF DE CETTE ETUDE EST L'APPLICATION DES FONCTIONS DU NIST CSF POUR LE SYSTÈME D'INFORMATION DE DAGOSTA IT, UNE PME DAKAROISE DE 25 EMPLOYES, EN TENANT COMPTE DE L'ABSENCE ACTUELLE DE SYSTÈME DE SECURITE FORMEL.

CAS PRATIQUE

PARTIE1 : IDENTIFICATION

CETTE PHASE PERMET DE COMPRENDRE LE CONTEXTE ET LES ACTIFS A PROTEGER.

1. INVENTAIRE DES ACTIFS CRITIQUES

ACTIFS CRITIQUES

MATERIEL : SERVEUR CENTRAL, 25 POSTES DE TRAVAILS (PC), ROUTEUR POUR LE RESEAU LOCAL
LOGICIEL : SYSTÈME D'EXPLOITATION DU SERVEUR, ANTIVIRUS
DONNEES : BASE DE DONNEES DES CLIENTS, FACTURES

2. ANALYSE DES RISQUES POSSIBLES

- PERTE DE DONNEES POSSIBLES : UNE ABSENCE DE SAUVEGARDE REGULIERE (RISQUE MAJEUR EN CAS DE PANNE DE MATERIELLE).
- RANSOMWARE : L'ANTIVIRUS BASIQUE ET L'ACCES INTERNET SANS PARE-FEU EXPOSENT LES FACTURES AU CHIFFREMENT MALVEILLANT.
- ACCES NON AUTORISE : MANQUE DE CONTROLES D'ACCES FORMEL SUR LE SERVEUR CONTENANT LES DONNEES DES CLIENTS.

PARTIE2 : PROTEGER

UNE MISE EN PLACE GARANTIE POUR LIMITER L'IMPACT D'UNE MENACE POTENTIELLE, NOUS PROPOSONS COMME MESURES DE PROTECTION DE :

- APPLIQUER LE MOINDRE PRVILEGE SUR LES ACCEES : C'EST-A-DIRE UN UTILISATEUR OU UN PROGRAMME NE DOIT AVOIR ACCES QU'AUX DROITS STRICTEMENT NECESSAIRE POUR ACCOMPLIR SA TACHE.

- METTRE EN PLACE DES SAUVEGARDE AUTOMATISEES ET REGULIERES

- CHIFFRER LES DONNEES SENSIBLES SUR LE SERVEUR

- INSTALLER UN PARE FEU.

PARTIE3 : DETECTER

QUELQUES METHODES POUR DETECTER LES INCIDENTS DE SECURITE :

- JOURNALISATION : ACTIVER ET CENTRALISER LES LOGS DU SYSTEME DU SERVEUR POUR ASSURER LEUR INTEGRITE.

- ALERTES D'ANOMALIES : METTRE EN PLACE UN SIEM QUI PERMET DE CENTRALISER ET ANALYSER LES EVENEMENTS DE SECURITE.

- ANALYSE DE VULNÉRABILITÉS : EFFECTUER DES SCANS RÉGULIERS POUR IDENTIFIER LES FAILLES LOGICIELLES NON CORRIGÉES.

PARTIE4 : REPONDRE

EN CAS D'ATTAQUE, LA REACTIVITE EST LA CLE POUR LIMITER LES DEGATS.

VOICI QUELQUES ETAPES ESSENTIELS EN SUIVANT LA METHODOLIE DE NIST SP 800-61

- CONFINER (ISOLER POUR PROTEGER) : DÉCONNECTER IMMÉDIATEMENT LES SYSTÈMES INFECTÉS DU RÉSEAU LOCAL POUR EMPÊCHER LA PROPAGATION DE L'ATTAQUE VERS LE SERVEUR ET LES AUTRES POSTES.

- ERADIQUER (NETTOYER LA MENACE) : SUPPRIMER DÉFINITIVEMENT LES COMPOSANTS MALVEILLANTS ET FERMER LES FAILLES DE SÉCURITÉ UTILISÉES PAR L'ATTAQUANT POUR S'INFILTRER.

- RECUPERER (RESTAURER LES SERVICES) : RESTAURER LES DONNÉES ET LES SERVICES À PARTIR DES SAUVEGARDES SAINES AFIN DE REPRENDRE LES ACTIVITÉS NORMALES DE L'ENTREPRISE.

- RETEX (RETOUR D'EXPERIENCE) : ANALYSER LES CAUSES DE L'INCIDENT ET LES ACTIONS MENÉES POUR AMÉLIORER LA STRATÉGIE DE SÉCURITÉ ET ÉVITER TOUTE RÉCIDIVE.

PARTIE5 : RECUPERER

PHASE DE REPRISE APRES L'INCIDENT :

- RESTAURATION DES DONNEES : VERIFIER L'INTEGRITE DES DONNEES AVANR DE LES REUTILISER.

- RECONNEXION PROGRESSIVE : REBRANCHER LES SYSTEMES AU RESEAU LOCAL EN PRIORISANT LES SERVICES CRITIQUES.

- VERIFICATION DE LA DISPONIBILITE : S'ASSURER QUE SERVEURS ET APPLICATION SONT PLEINEMENT ACCESSIBLES AUX EMPLOYES.

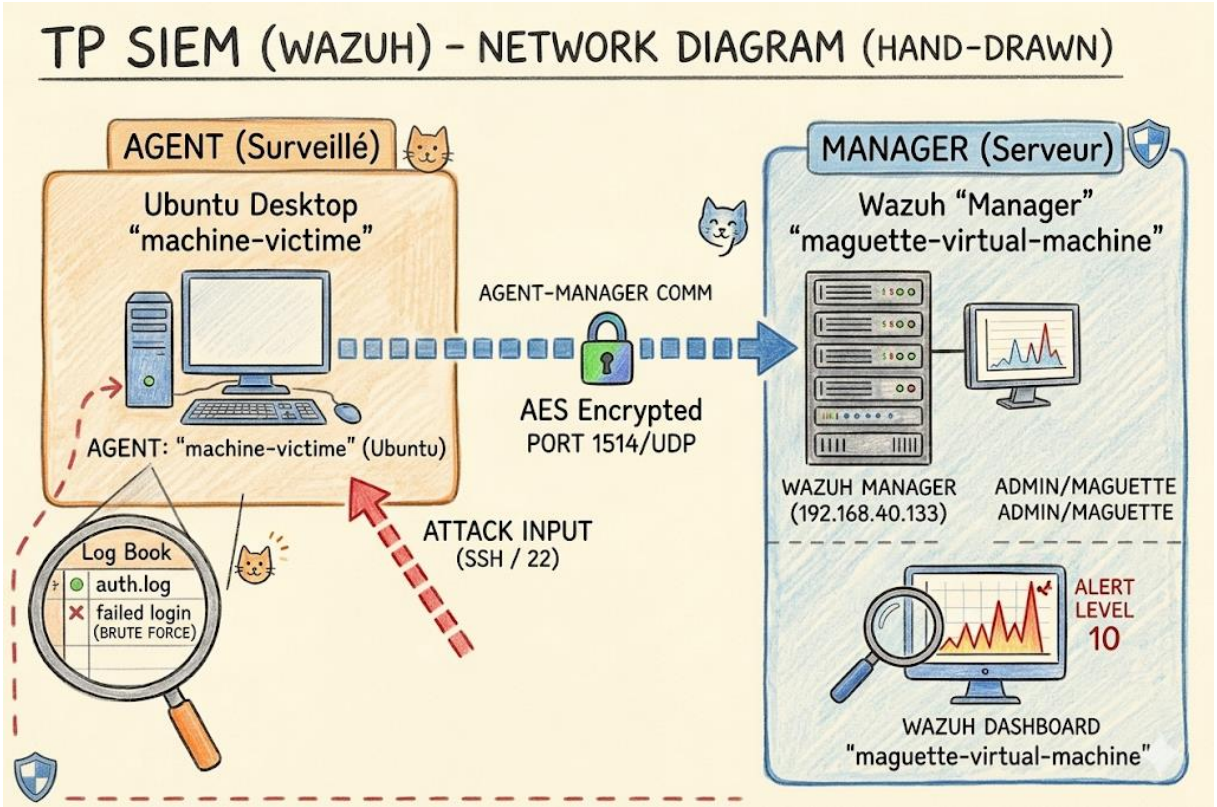
- MISE A JOUR DE LA STRATEGIE : INTEGRER LES ENSEIGNEMENTS DU RETOUR D'EXPERIENCE AFIN DE RENFORCER LES MESURES DE PROTECTION.

TABLEAU D'EVALUATION

IL PERMET DE RÉSUMER EN UN SEUL COUP D'ŒIL TOUTES LES FAILLES DE SÉCURITÉ DE LA PME DAGOSTA IT SANS NOYER LE LECTEUR DANS DES DÉTAILS TECHNIQUES TROP COMPLEXES.

FONCTION NIST	ETAT ACTUEL	RISQUE	SOLUTION PROPOSEE
IDENTIFIER	PARTIEL	MOYEN	FAIRE L'INVENTAIRE DES 25 PC ET DU SERVEUR
PROTEGER	FAIBLE	CRITIQUE	INSTALLER UN ANTIVIRUS ET UN PARE-FEU
DETECTER	INEXISTANT	ELEVE	ACTIVER LA SURVEILLANCE DES CONNEXIONS LOG (SIEM)
REPONDRE	INEXISTANT	ELEVE	CREER UN PLAN DE REPONSE AUX INCIDENTS
RECUPERER	FAIBLE	MOYEN	AUTOMATISER LES SAUVEGADES

SCHEMA RESEAU SECURISE



MISE EN ŒUVRE D'UN SIEM AVEC WAZUH

Plan du rapport :

I. Installation : Déploiement automatisé de la solution WAZUH (Indexer, Server, Dashboard).

II. Configuration : Paramétrage des agents et sécurisation des accès.

III. Test d'attaque : Simulation d'incidents (Brute force) pour tester la détection.

IV. Résultats d'alerte : Analyse des logs et visualisation des menaces sur le tableau de bord.

L'objectif de ce TP est de mettre en place une solution de monitoring de sécurité SIEM pour surveiller un serveur Linux.

I. INSTALLATION

- Préparation et lancement de l'installation automatisée de WAZUH

```
maguette@maguette-virtual-machine:~$ curl -sO https://packages.wazuh.com/4.7/wazuh-install.sh
maguette@maguette-virtual-machine:~$ head -5 wazuh-install.sh
#!/bin/bash

# Wazuh installer
# Copyright (C) 2015, Wazuh Inc.
#
maguette@maguette-virtual-machine:~$  curl -sO https://packages.wazuh.com/4.7/config.yml
maguette@maguette-virtual-machine:~$ ls -lh wazuh-install.sh config.yml
-rw-rw-r-- 1 maguette docker  636 awr  8 14:04 config.yml
-rw-rw-r-- 1 maguette docker 162K awr  8 14:03 wazuh-install.sh
maguette@maguette-virtual-machine:~$ curl -sO https://packages.wazuh.com/4.7/config.yml

maguette@maguette-virtual-machine:~$ ls -lh wazuh-install.sh config.yml

-rw-rw-r-- 1 maguette docker  636 awr  8 14:06 config.yml
-rw-rw-r-- 1 maguette docker 162K awr  8 14:03 wazuh-install.sh
maguette@maguette-virtual-machine:~$  sudo bash wazuh-install.sh -a
```

L'image nous montre le téléchargement et le lancement du script officiel pour installer automatiquement tous les composants de WAZUH.

Les commandes utilisées :

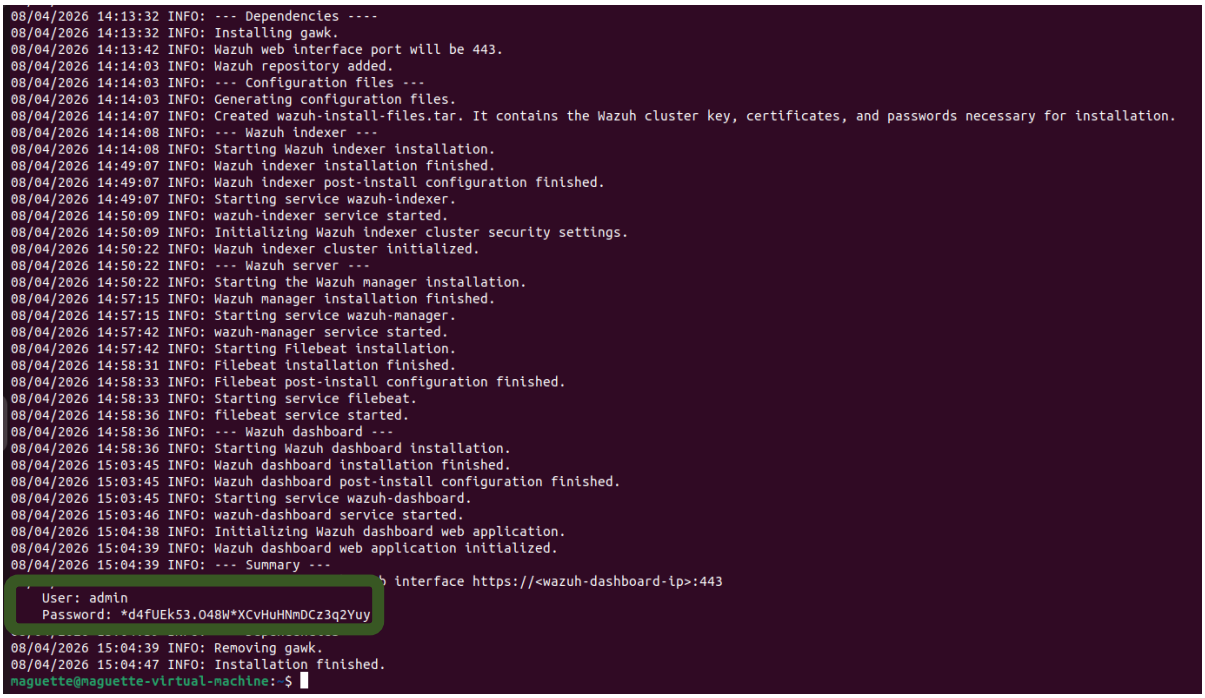
CURL : Télécharge les fichiers d'installation depuis le serveur de WAZUH

HEAD -5 : Affiche les 5 premières lignes du script pour vérifier son contenu.

LS -LH : Liste les fichiers pour confirmer qu'ils sont bien présents et lisibles.

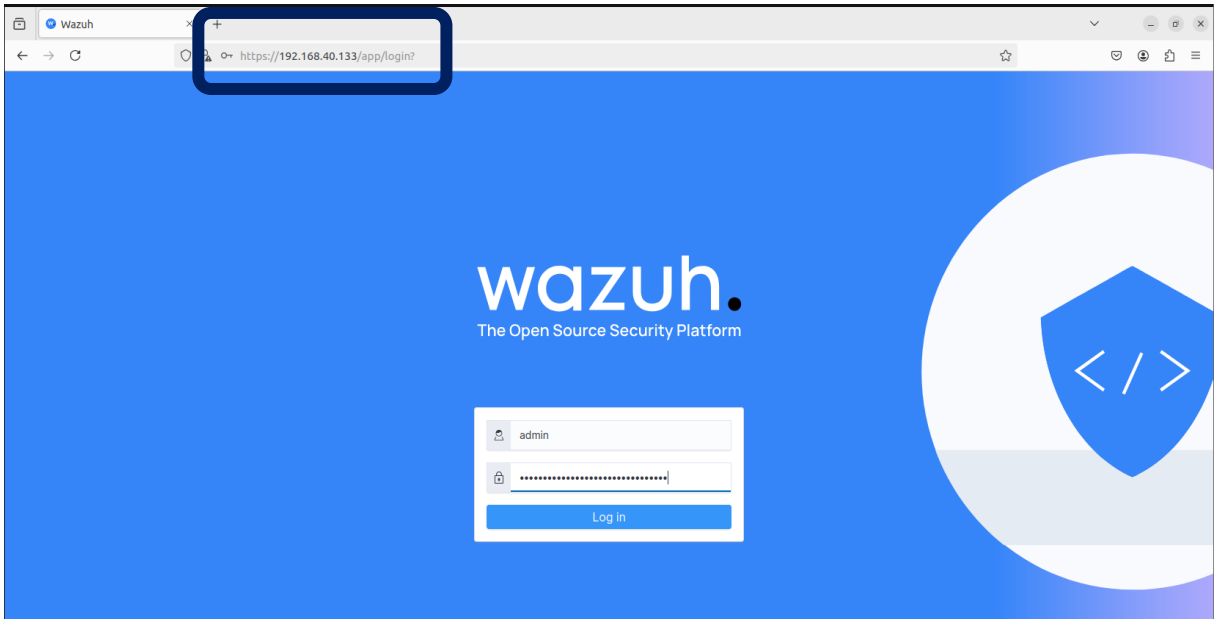
SUDO BASH... -A : Exécute l'installation complète de tous les services en mode administrateur.

- <u>Fin de l'installation et récapitulatif des identifiants WAZUH.</u>



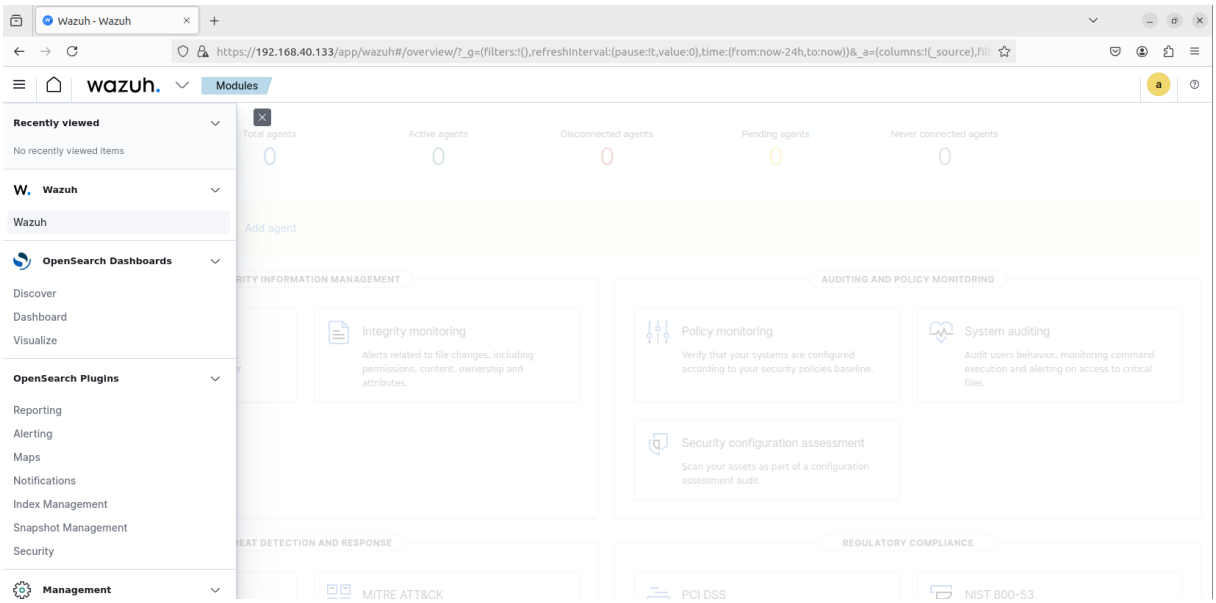
L'image montre que l'installation automatique s'est terminée avec succès (installation finished).
Elle détaille :
- le déploiement des composants de WAZUH indexer, server et Dashboard sont installes et démarrés.
- la génération des clés : création des certificats et mot de passe de sécurité.
- les accès : affichage de l’url de l’interface web du compte administrateur admin et mot de passe générée.

- Interface de connexion au tableau de bord WAZUH



Cette image montre l'accès web a la plateforme avec comme url : https://ip 192.168.40.133 (IP de mon Ubuntu) et une saisie des identifiants (utilisateur admin et mot de passe généré précédemment pour accéder à l'interface de gestion SIEM.

- Tableau de bord principal (Dashboard) et aperçu des modules WAZUH



Présentation de l’interface WAZUH.

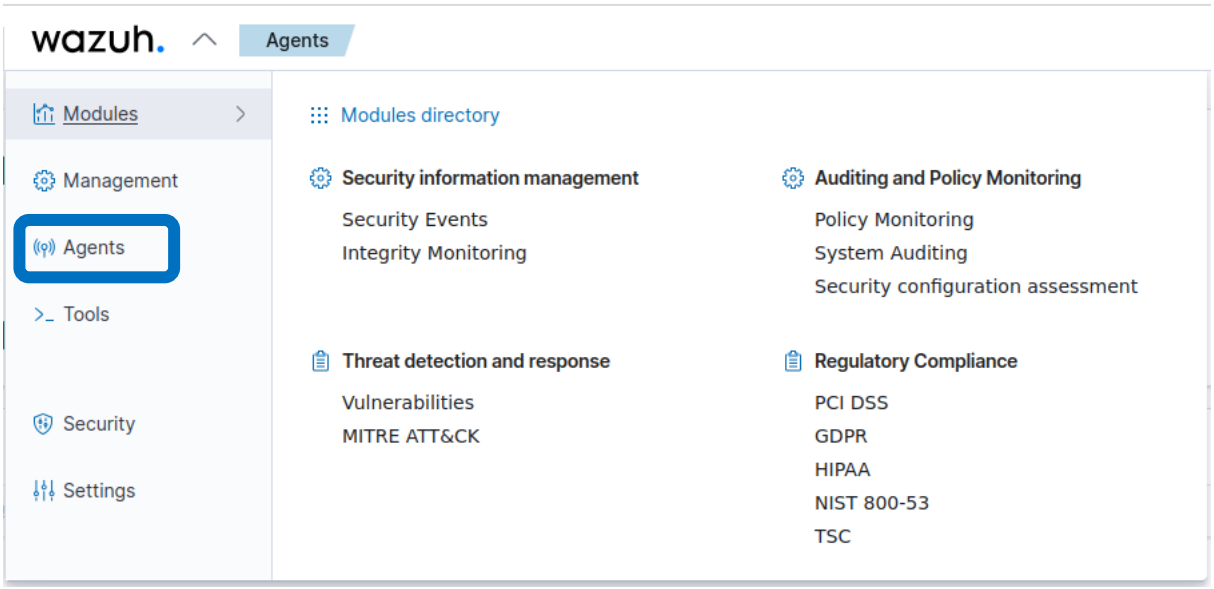
II. Configuration

- Identification de l'adresse IP de la VM victime.

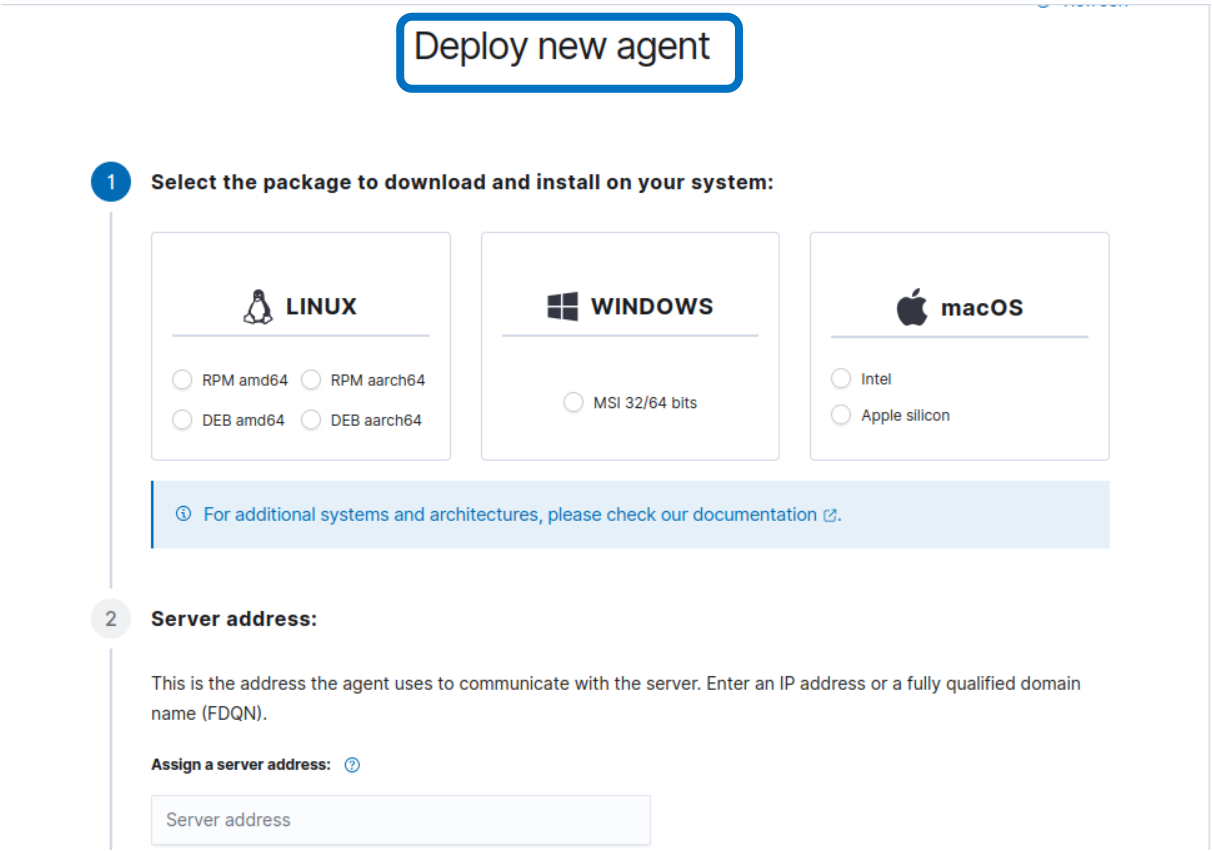
```
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
2: ens33: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:ec:b0:9d brd ff:ff:ff:ff:ff:ff
    altn
    inet 192.168.40.129/24 metric 100 brd 192.168.40.255 scope global dynamic ens33
       v eferred_lft 1600sec
    inet6 fe80::20c:29ff:feec:b09d/64 scope link
       valid_lft forever preferred_lft forever
3: docker0: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group default
    link/ether e2:13:ab:42:1e:49 brd ff:ff:ff:ff:ff:ff
4: br-fad15d7d70f0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether fe:ff:48:f6:12:88 brd ff:ff:ff:ff:ff:ff
    inet6 fe80::fcff:48ff:fef6:1288/64 scope link
       valid_lft forever preferred_lft forever
5: veth73251d7@if2: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue master br-fad15d7d70f0
state UP group default
    link/ether a2:b2:79:e9:03:a6 brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet6 fe80::a0b2:79ff:fee9:3a6/64 scope link
       valid_lft forever preferred_lft forever
7: vethd370e3c@if2: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue master br-fad15d7d70f0
state UP group default
    link/ether 5e:54:d8:f9:2f:8d brd ff:ff:ff:ff:ff:ff link-netnsid 2
    inet6 fe80::5c54:d8ff:fef9:2f8d/64 scope link
       valid_lft forever preferred_lft forever
8: veth5bf8275@if2: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue master br-fad15d7d70f0
state UP group default
    link/ether 92:1f:30:03:b0:e0 brd ff:ff:ff:ff:ff:ff link-netnsid 3
    inet6 fe80::901f:30ff:fe03:b0e0/64 scope link
       valid_lft forever preferred_lft forever
510: vethad5f530@if2: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue master br-fad15d7d70f
0 state UP group default
    link/ether 5e:7d:7d:c8:2d:e7 brd ff:ff:ff:ff:ff:ff link-netnsid 1
    inet6 fe80::5c7d:7dff:fec8:2de7/64 scope link
       valid_lft forever preferred_lft forever
maguette@maguette:~$ _
```

On identifie l'adresse **192.168.40.129** sur l'interface ens33, qui servira de cible pour les tests d'intrusion et la remontée d'alertes vers WAZUH.

- <u>Création de l'agent</u>

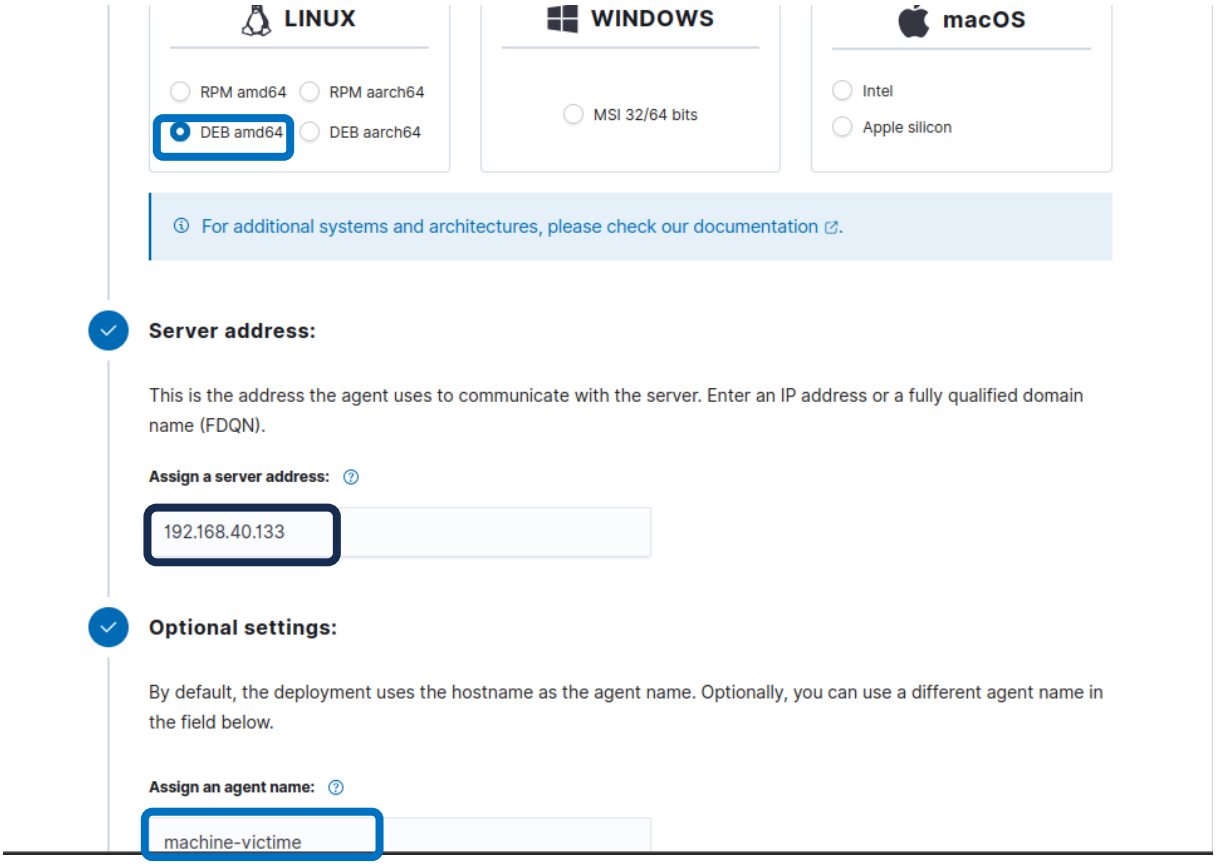


- Configuration du déploiement de l'agent



C'est ici que l'on prépare la commande pour créer l'agent sur la machine victime afin qu'elle puisse communiquer avec le serveur WAZUH.

- Validation des paramètres de l'agent



Confirmation de l'IP du Manager et du nom de l'agent (machine-victime).

- Commandes d'installation et démarrage de l'agent

Select one or more existing groups:

default ×

4 **Run the following commands to download and install the agent:**

```
wget https://packages.wazuh.com/4.x/apt/pool/main/w/wazuh-agent/wazuh-agent_4.7.5-1_amd64.deb &&
sudo WAZUH_MANAGER='192.168.40.133' WAZUH_AGENT_GROUP='default' WAZUH_AGENT_NAME='machine-victime'
dpkg -i ./wazuh-agent_4.7.5-1_amd64.deb
```

Requirements

- You will need administrator privileges to perform this installation.
- Shell Bash is required.

Keep in mind you need to run this command in a Shell Bash terminal.

5 **Start the agent:**

```
sudo systemctl daemon-reload
sudo systemctl enable wazuh-agent
sudo systemctl start wazuh-agent
```

Cette étape automatise l'installation sur la machine victime. Elle permet de télécharger le paquet, de configurer l'agent et de l'activer pour qu'il commence à envoyer des données en temps réel.

- <u>Exécution de l'installation sur la machine victime</u>

```
maguette@maguette:~$ wget https://packages.wazuh.com/4.x/apt/pool/main/w/wazuh-agent/wazuh-agent_4.7.5-1_amd64.deb && sudo WAZUH_MANAGER='192.168.40.133' WAZUH_AGENT_GROUP='default'
 WAZUH_AGENT_NAME='machine-victime' dpkg -i ./wazuh-agent_4.7.5-1_amd64.deb
--2026-04-11 13:35:38--  https://packages.wazuh.com/4.x/apt/pool/main/w/wazuh-agent/wazuh-agent_4.7.5-1_amd64.deb
Resolving packages.wazuh.com (packages.wazuh.com)... 108.157.78.23, 108.157.78.113, 108.157.78.21, ...
Connecting to packages.wazuh.com (packages.wazuh.com)|108.157.78.23|:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: 9378818 (8.9M) [application/vnd.debian.binary-package]
Saving to: 'wazuh-agent_4.7.5-1_amd64.deb'

wazuh-agent_4.7.5-1 100%[===================>]   8.94M  1.18MB/s    in 13s

2026-04-11 13:35:53 (684 KB/s) - 'wazuh-agent_4.7.5-1_amd64.deb' saved [9378818/9378818]

[sudo] password for maguette:
Selecting previously unselected package wazuh-agent.
(Reading database ... 111371 files and directories currently installed.)
Preparing to unpack .../wazuh-agent_4.7.5-1_amd64.deb ...
Unpacking wazuh-agent (4.7.5-1) ...
Setting up wazuh-agent (4.7.5-1) ...
maguette@maguette:~$
```

Ici j'ai utilisé les commandes wget dpkg générées lors de l'installation de l'agent sur la machine victime :

wget https://packages.wazuh.com/4.x/apt/pool/main/w/wazuh-agent/wazuh-agent_4.7.5-1_amd64.deb && sudo WAZUH_MANAGER='192.168.40.133' WAZUH_AGENT_GROUP='default' WAZUH_AGENT_NAME='machine-victime' dpkg -i ./wazuh-agent_4.7.5-1_amd64.deb.

La capture montre aussi que l’agent est correctement installé.

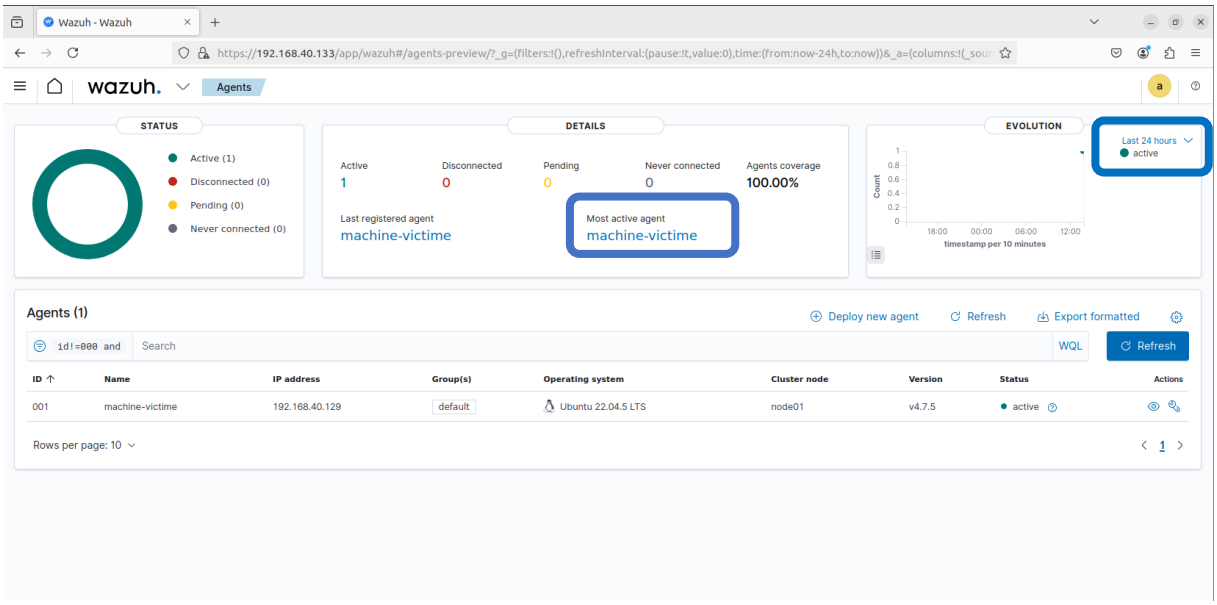
- <u>Activation et démarrage du service de l'agent</u>

```
maguette@maguette:~$ sudo systemctl daemon-reload
sudo systemctl enable wazuh-agent
sudo systemctl start wazuh-agent
Created symlink /etc/systemd/system/multi-user.target.wants/wazuh-agent.service → /lib/systemd/system/wazuh-agent.service.
maguette@maguette:~$
```

Cette étape rend l'agent opérationnel. La création du "symlink" confirme que le service est désormais enregistré dans le système et prêt à communiquer avec le Manager.

- <u>Vérification de la connexion de l'agent</u>

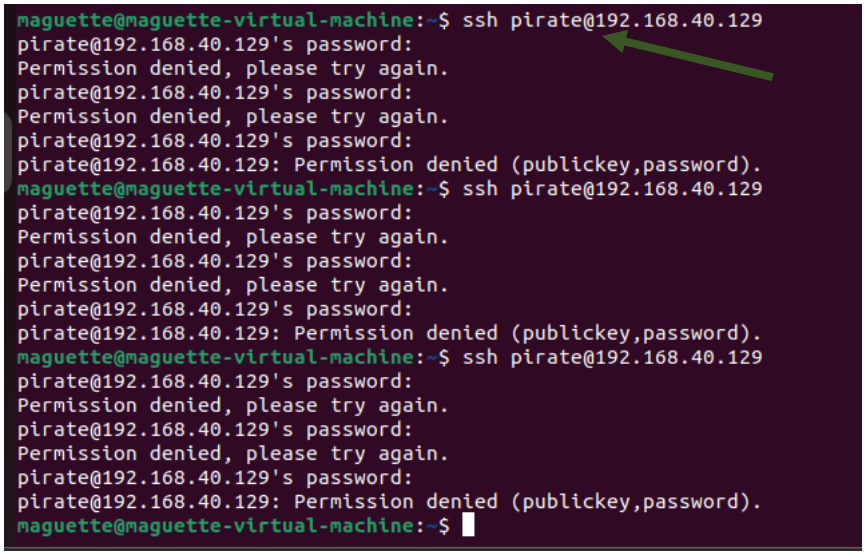
Le tableau de bord affiche l'IP **192.168.40.129** pour l'agent nommé "machine-victime".



Cette capture confirme le succès du déploiement. L'agent communique correctement avec le Manager (192.168.40.133) et le SIEM est maintenant prêt à recevoir et analyser les événements de sécurité de la cible.

III. Test d'attaque

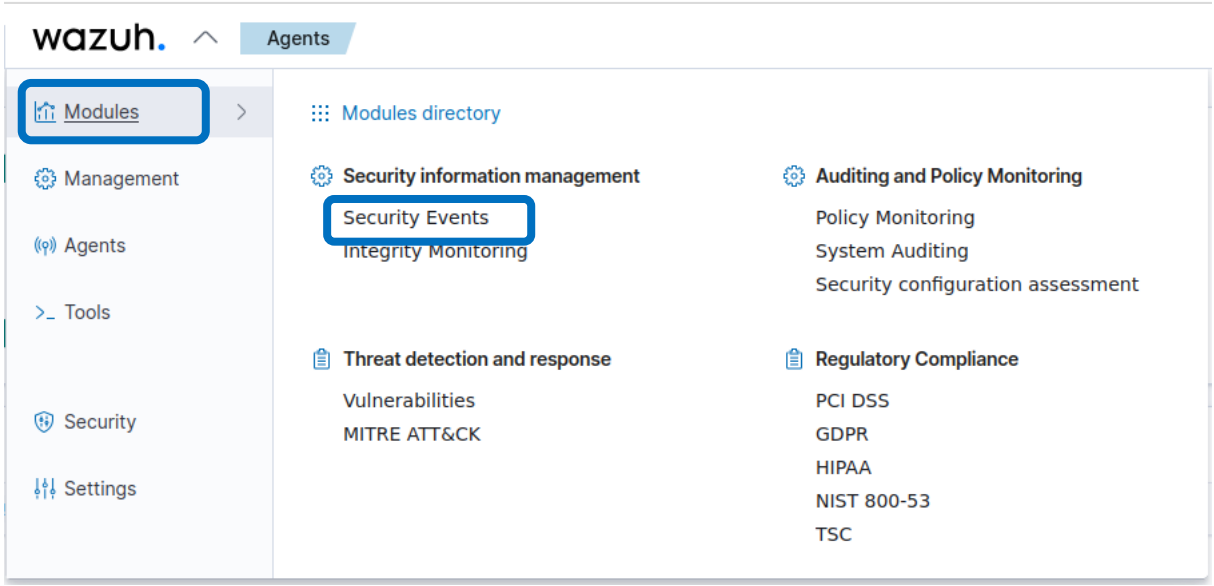
- Simulation d'une attaque par force brute SSH



Tentatives répétitives de connexion ssh sur la machine cible, avec comme utilisateur ‘’ pirate ’’, Cette action simule une activité suspecte. Le but est de générer un grand nombre de logs d'échecs d'authentification en un temps réduit pour déclencher une alerte de niveau élevé sur WAZUH.

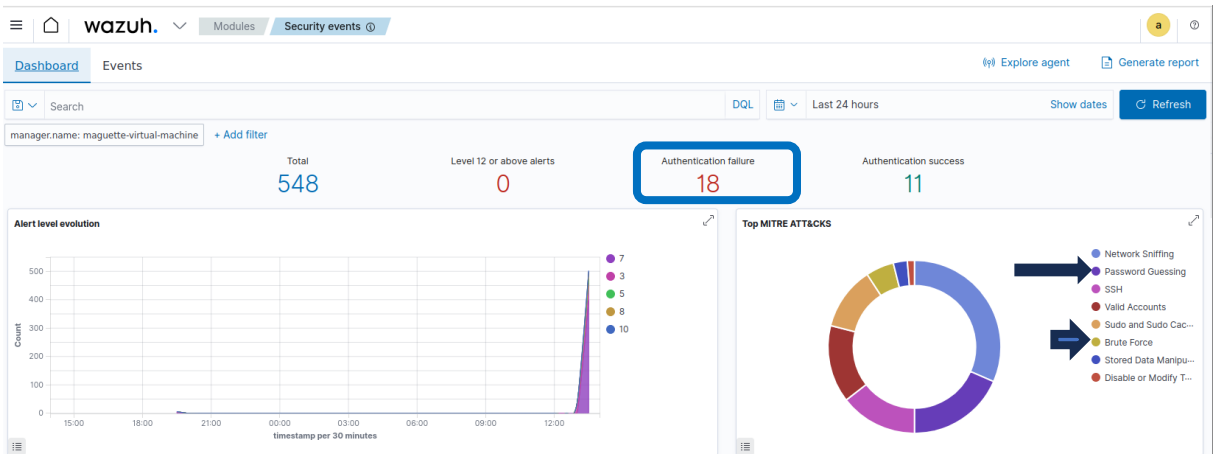
IV. Résultats d’attaques

- Analyse des événements de sécurité



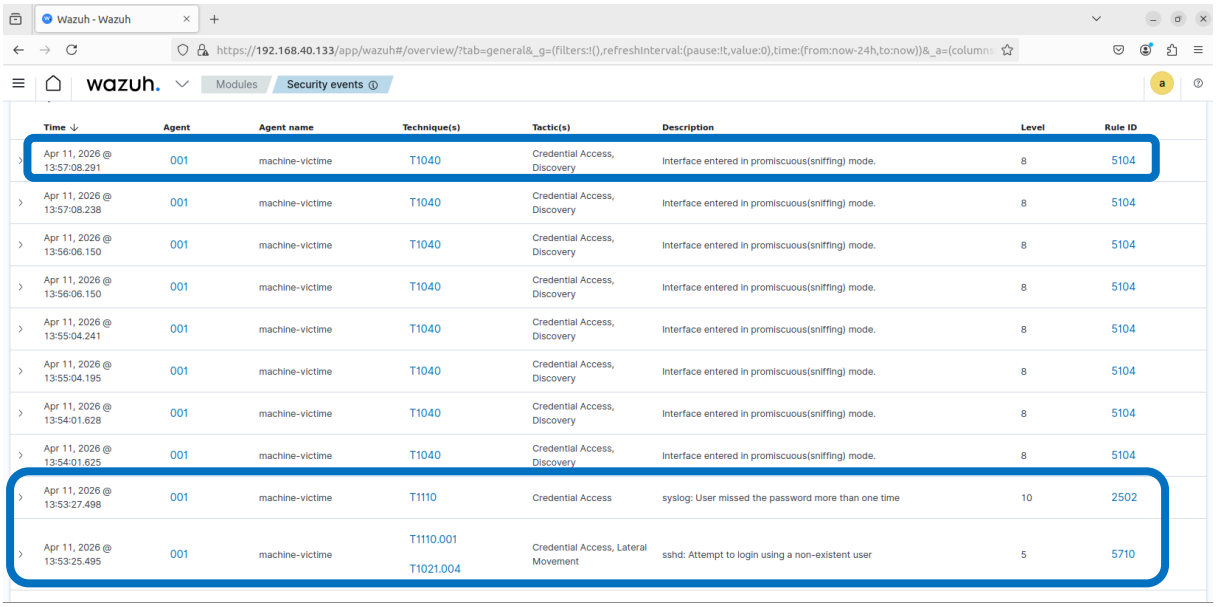
Pour voir les résultats, on se rend dans le menu **Modules** et on clique sur **"Security Events"**.

- Tableau de bord des alertes de sécurité



Dashboard "Security Events" montre un pic d'activité. Nous observons **18 échecs d'authentification** et la détection d'attaques de type **Brute Force** et **Password Guessing** dans le graphique MITRE ATT&CK.

- <u>Chronologie des alertes de sécurité</u>



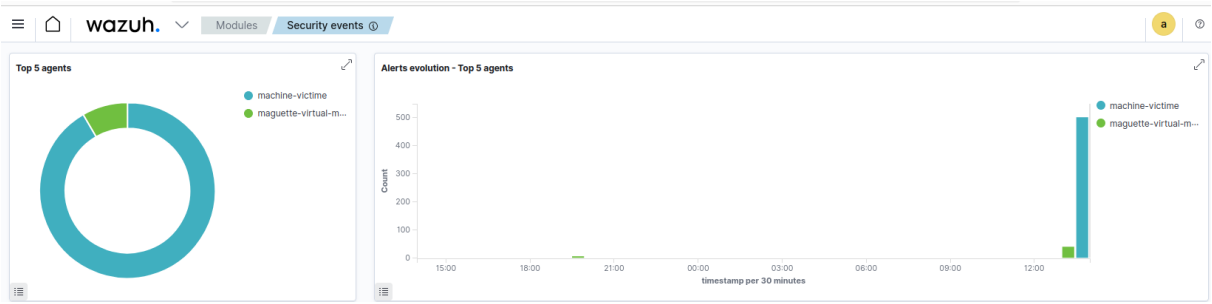
Time	Agent	Agent name	Technique(s)	Tactic(s)	Description	Level	Rule ID
Apr 11, 2026 @ 13:57:08.291	001	machine-victime	T1040	Credential Access, Discovery	Interface entered in promiscuous(sniffing) mode.	8	5104
Apr 11, 2026 @ 13:57:08.238	001	machine-victime	T1040	Credential Access, Discovery	Interface entered in promiscuous(sniffing) mode.	8	5104
Apr 11, 2026 @ 13:56:06.150	001	machine-victime	T1040	Credential Access, Discovery	Interface entered in promiscuous(sniffing) mode.	8	5104
Apr 11, 2026 @ 13:56:06.150	001	machine-victime	T1040	Credential Access, Discovery	Interface entered in promiscuous(sniffing) mode.	8	5104
Apr 11, 2026 @ 13:55:04.241	001	machine-victime	T1040	Credential Access, Discovery	Interface entered in promiscuous(sniffing) mode.	8	5104
Apr 11, 2026 @ 13:55:04.195	001	machine-victime	T1040	Credential Access, Discovery	Interface entered in promiscuous(sniffing) mode.	8	5104
Apr 11, 2026 @ 13:54:01.628	001	machine-victime	T1040	Credential Access, Discovery	Interface entered in promiscuous(sniffing) mode.	8	5104
Apr 11, 2026 @ 13:54:01.625	001	machine-victime	T1040	Credential Access, Discovery	Interface entered in promiscuous(sniffing) mode.	8	5104
Apr 11, 2026 @ 13:53:27.498	001	machine-victime	T1110	Credential Access	syslog: User missed the password more than one time	10	2502
Apr 11, 2026 @ 13:53:25.495	001	machine-victime	T1110.001 T1021.004	Credential Access, Lateral Movement	sshd: Attempt to login using a non-existent user	5	5710

predecoder.timestamp	Apr 11 13:53:26
rule.description	syslog: User missed the password more than one time
rule.firedtimes	3
rule.gdpr	IV_35.7.d, IV_32.2
rule.gpg13	7.8
rule.groups	syslog, access_control, authentication_failed
rule.hipaa	164.312.b
rule.id	2502
rule.level	10
rule.mail	false
rule.mitre.id	T1110
rule.mitre.tactic	Credential Access
rule.mitre.technique	Brute Force
rule.nist_800_53	AU.14, AC.7
rule.pci_dss	10.2.4, 10.2.5
rule.tsc	CC6.1, CC6.8, CC7.2, CC7.3

- Ligne du bas (13:53:25) : Détection d'une tentative de connexion avec un utilisateur inexistant (Rule 5710). C'est le début de la reconnaissance.
- Ligne juste au-dessus (13:53:27) : L'alerte de niveau 10 (Brute Force) se déclenche car le système voit que l'attaquant insiste (Rule 2502).

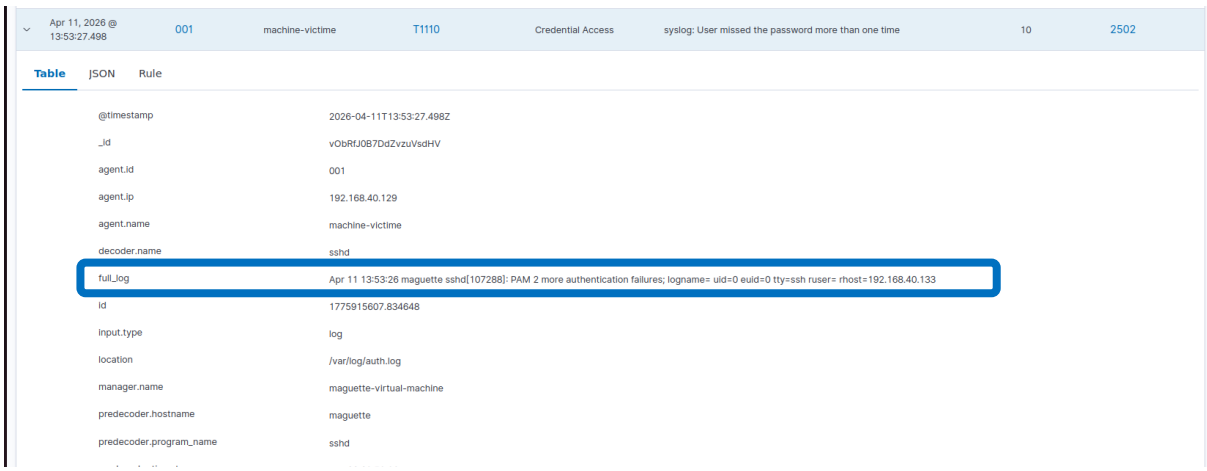
- Lignes du haut (T1040) : On remarque aussi des alertes de niveau 8 concernant le "promiscuous mode" (sniffing). Cela suggère que l'agent a détecté une tentative d'écoute réseau sur l'interface de la victime.

- Identification des agents les plus ciblés



Le graphique en barres (**Alerts evolution**) confirme que l'attaque par force brute a généré un volume d'événements anormalement élevé en un temps très court. Cela permet à l'administrateur de visualiser immédiatement quelle machine du parc est sous le coup d'une tentative d'intrusion.

- <u>Détails techniques d'un événement de sécurité</u>



<u>Preuve de l'attaque</u> : Le champ full_log montre que le service **sshd** a enregistré plusieurs échecs d'authentification PAM pour l'utilisateur "pirate" provenant de l'IP du manager (utilisé ici comme source d'attaque pour le test).

FIN.